Muster Elektrotechnik e.U.

ENTWURF · fehlt: Postanschrift des Betriebs, Empfänger, Name der unterzeichnenden Person. Vor dem Versand die Antworten ergänzen.

[Postanschrift des Betriebs]

[Name und Anschrift des Kunden oder Versicherers]

[Ort], 23. Oktober 2026

Betreff: Sicherheitsnachweis von Muster Elektrotechnik e.U.

Sehr geehrte Damen und Herren,

vielen Dank für Ihren Sicherheitsfragebogen. Beigelegt finden Sie unsere Selbstauskunft Informationssicherheit mit Stand 23. Oktober 2026. Sie beantwortet die Fragen zum Stand unserer Informationssicherheit; wo Ihr Fragebogen etwas fragt, was die Selbstauskunft nicht abdeckt, zeigt die Abgleichtabelle auf der folgenden Seite, wo die Antwort steht, oder wir antworten auf Anfrage schriftlich.

Muster Elektrotechnik e.U. ist ein Betrieb mit 10 bis 49 Beschäftigten ohne eigene IT-Abteilung. Wir erbringen Leistungen vor Ort oder in unserer Werkstatt und verarbeiten dabei einige Kundendaten (Kontakte, Pläne, Aufträge). Die beschriebenen Maßnahmen sind die eines Betriebs unserer Größe; Artikel 21 Absatz 1 der NIS-2-Richtlinie (EU) 2022/2555 nennt die Größe der Einrichtung ausdrücklich unter den Kriterien der Verhältnismäßigkeit.

Von den 24 Punkten der Selbstauskunft sind heute 7 vorhanden, 10 teilweise, 6 noch nicht, 1 auf uns nicht anwendbar. Für jeden Punkt, der teilweise oder noch nicht vorhanden ist, nennt der beigelegte Maßnahmenplan die Maßnahme, die verantwortliche Person und den Termin: die erste Welle bis 22. November 2026, der Rest bis 21. April 2027. Wir nennen lieber eine Lücke mit Termin, als ein Ja zu schreiben, das nicht stimmt.

Vorfälle, die Sie betreffen könnten, melden wir innerhalb von 24 Stunden nach Kenntnis, telefonisch, durch die Leitung oder ihre Vertretung; die Meldung kommt von Inhaber oder Geschäftsführung, +43 660 000 00 01 (Beispiel), buero@muster.at.

Ist einer der offenen Punkte Bedingung für den Vertrag oder die Police, sagen Sie uns bitte Bescheid; wir ziehen ihn in die erste Welle vor.

Anlagen: Selbstauskunft Informationssicherheit; Maßnahmenplan; Nachweisliste mit den Unterlagen Anl. 1 bis 3.

Mit freundlichen Grüßen

[Name]

Inhaber oder Geschäftsführung, Muster Elektrotechnik e.U.

Fragebogen-Abgleich

Fragebögen verschiedener Kunden fragen zum größten Teil dasselbe, in anderen Worten und anderer Reihenfolge. Diese Tabelle ordnet die typischen Fragen den Abschnitten der Selbstauskunft und den Bereichen des Artikels 21 Absatz 2 der NIS-2-Richtlinie zu, mit unserer Antwort in Kurzform.

Typische Frage	Selbstauskunft	Art. 21 Abs. 2	Unsere Antwort
Wer ist für Informationssicherheit verantwortlich, und wie erreichen wir die Person?	A	a, i	Inhaber oder Geschäftsführung, +43 660 000 00 01 (Beispiel), buero@muster.at; Vertretung: Büroleitung
Gibt es schriftliche Sicherheitsregeln oder eine Richtlinie?	B	a	Teilweise, bis 21. Jänner 2027
Haben Sie ein Zertifikat (ISO 27001, Gütesiegel) oder Prüfberichte?	B	f	Keine
Haben Sie eine Cyberversicherung?	B	nicht in Art. 21 Abs. 2	Nein
Ist Multi-Faktor-Authentifizierung für E-Mail, Fernzugriff und Administration erzwungen?	C	j	MFA für E-Mail: vorhanden (Authenticator-App); MFA für Fernzugriff und Administration: teilweise (VPN ja, die Administrationskonsole der Cloud noch nicht), bis 22. November 2026
Wie werden Zugriffsrechte beim Ausscheiden entzogen?	C	i	Teilweise, bis 21. Jänner 2027
Welche Passwortregel gilt, und sind Administratorrechte beschränkt?	C	i	Passwortregel: teilweise, bis 21. Jänner 2027; Administratorrechte: noch nicht, bis 21. Jänner 2027
Wie oft sichern Sie, liegt eine Kopie offline, und wann wurde eine Wiederherstellung geprobt?	D	c	Sicherung: teilweise (täglich auf das NAS im Büro, keine Offline-Kopie), bis 22. November 2026; Wiederherstellungstest: noch nicht, bis 22. November 2026
Wie lange überbrücken Sie einen IT-Ausfall, haben Sie eine Wiederherstellung geprobt, und gibt es einen Notfallplan?	D	c	Tolerierbare Ausfallzeit: etwa einen Tag; Wiederherstellungstest: noch nicht, bis 22. November 2026; Notfallplan: noch nicht, bis 22. November 2026
Innerhalb welcher Zeit werden Updates installiert, und werden alle Systeme unterstützt?	E	e	Updates: vorhanden; Geräteliste: teilweise (keine schriftliche Liste; der Werkstattrechner läuft noch mit einem alten System), bis 21. Jänner 2027
Sind Geräte geschützt und verschlüsselt, und ist das Netz segmentiert?	E	e, h	Schutz und Verschlüsselung: vorhanden; Router und Gastnetz: teilweise (Gastnetz ja, Firmware und Passwort unbekannt), bis 21. Jänner 2027
Wie behandeln Sie Schwachstellen in Ihren Produkten?	E	e	Nicht anwendbar: Wir liefern keine Software und keine Geräte
Innerhalb welcher Zeit melden Sie uns Vorfälle?	F	b	Innerhalb von 24 Stunden nach Kenntnis, telefonisch, durch die Leitung oder ihre Vertretung
Gab es in den letzten 24 Monaten Vorfälle, und protokollieren Sie sie?	F	b	Vorfälle: keine bekannt; Vorfallsprotokoll: noch nicht, bis 21. Jänner 2027

Typische Frage	Selbstauskunft	Art. 21 Abs. 2	Unsere Antwort
Schulen Sie Ihre Beschäftigten, und sind sie zur Vertraulichkeit verpflichtet?	G	g, i	Einweisung: noch nicht, bis 21. Jänner 2027; Vertraulichkeit: vorhanden
Welche Unterauftragnehmer verarbeiten unsere Daten, wo, und mit welchen Verträgen?	H	d	Dienstleisterliste: teilweise, bis 21. Jänner 2027; Auftragsverarbeitungsverträge und Konsoleneinstellungen: teilweise, bis 21. Jänner 2027; Information vor Dienstleisterwechsel: noch nicht, bis 21. April 2027
Wie werden unsere Daten bei Vertragsende zurückgegeben oder gelöscht?	I	nicht in Art. 21 Abs. 2	Vorhanden
Dürfen wir Sie prüfen oder Nachweise erhalten?	B, I	f	Nachweisliste (D4): Wir legen sie und die Dokumente dahinter auf Anfrage vor und erneuern die Selbstauskunft einmal im Jahr; Prüfungen vor Ort nach Vereinbarung, mit Ankündigung und auf Kosten der prüfenden Seite.

Erzeugt mit dem Sicherheitsnachweis-Toolkit von Scutoria aus den Antworten des Betriebs. Lücken werden mit Termin genannt, nie versteckt; nichts hier verspricht, dass der Betrieb eine Vorschrift erfüllt. Quellen am Original gelesen am 23. Oktober 2026: Richtlinie (EU) 2022/2555, Art. 21 Abs. 1 und 2; Verordnung (EU) 2022/2554 (DORA), Art. 30. Quellenbasiert. Keine Rechtsberatung.